



WP Plugin Auditor v1.0.0 - open-source WordPress plugin that performs automated static security analysis on any installed plugin, directly from the WordPress admin

GIT - <https://github.com/ssmason/WP-Plugin-Auditor>

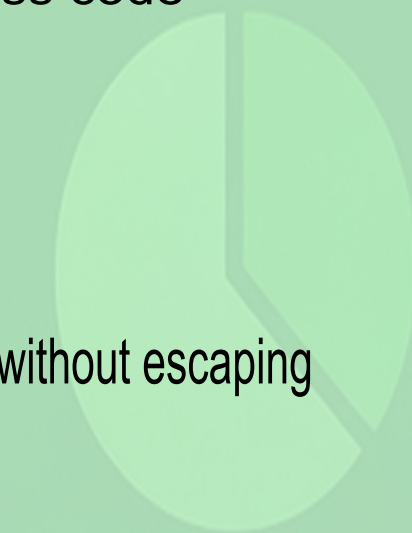
- Runs 29 security and code quality checks - from dangerous functions and SQL injection to unescaped output, hardcoded credentials, and nonce verification - reporting both findings and confirmed passes
- Zero friction workflow - one click from the Plugins page opens an inline modal with a live progress bar; reports are stored, retrievable, and exportable as JSON
- Built to WordPress.org submission standards - WPCS, PHPStan level 8, strict types, full AJAX security, capability checks, and multisite-aware uninstall
- Finds its own bugs - the plugin passes its own audit at CLEAN, validating the scanner against production-grade WordPress code

AUDITS

1. Dangerous functions (eval, exec, shell_exec, base64_decode, etc.)
2. Output escaping — unescaped echo, wrong escape function, _e() / __() without escaping
3. Input sanitization — unsanitized superglobals, missing wp_unslash()
4. Nonce verification — forms, AJAX handlers, GET actions
5. Capability checks — admin pages, write operations
6. Database queries — unprepared statements, raw mysql_* calls
7. Hardcoded credentials — passwords, API keys, tokens (value redacted in report)
8. Error suppression — error_reporting(0), ini_set on error settings
9. Obfuscated calls — variable variables, dynamic function names, preg_replace /e
10. Direct file access guard — missing defined('ABSPATH') || exit
11. Debug output PHP — var_dump, print_r, var_export
12. Debug output JS — console.log, console.warn, etc.
13. File permissions — world-writable files, PHP files with execute bit
14. Deprecated WordPress functions
15. Plugin structure — missing index.php sentinels, exposed readme files
16. Licensing — LICENSE file present, GPL-compatible license declared
17. PHP compatibility — PHP 8.0/8.1 features vs declared minimum version
18. Commented-out code — blocks of 5+ consecutive comment lines
19. Plugin header / metadata — missing required headers
20. External HTTP requests — all outbound calls reported as informational
21. Asset versioning — hardcoded version strings or false version argument
22. Redirect without exit — wp_redirect / wp_safe_redirect not followed by exit
23. Role name in current_user_can() — role names passed instead of capability names
24. Shortcode output escaping — unescaped return values in shortcode callbacks
25. Option writes without capability check — update_option, add_option, delete_option
26. Wrong \$wpdb->prepare() placeholder — %s for integers, %d for strings
27. Duplicate hook registrations — same hook/callback/priority registered more than once
28. Unnecessary closures — function() { return true; } instead of __return_true
29. Early translation calls — translation functions called at file scope before init



AUDIT RESULTS





Plugin Audit report that Failed and clearly identifies issues

Vanilla Hair and Beauty

2

0

New

2

Howdy, wp-admin

Media

Pages

Comments

Google Reviews

Services

Manifest

Portfolio

Team

Appearance

Plugins1

Users

Tools

Available Tools

Import

Export

Site Health

Export Personal Data

Erase Personal Data

Plugin Auditor

Plugin Audit Reports

Bedrock: Search engine indexing has been discouraged because the current environment is development.

☐	Plugin	Risk	High	Medium	Low	Date	Actions
☐	Satori ACF Field Loop	CLEAN	8	0	2	2026-04-21 09:04	View Download JSON
☐	Plugin Auditor	CLEAN	0	0	0	2026-04-21 09:03	View Download JSON
☐	Plugin Auditor	MEDIUM	1	1	0	2026-04-21 08:52	View Download JSON
☐	Satori Manifest	CRITICAL	25	0	11	2026-04-21 08:51	View Download JSON
☐	Satori Manifest	CRITICAL	25	0	11	2026-04-21 08:47	View Download JSON
☐	Satori Post Carousel	CRITICAL	10	13	0	2026-04-21 08:47	View Download JSON
☐	Satori Post Carousel	CRITICAL	10	13	0	2026-04-21 08:44	View Download JSON
☐	Satori Manifest	CRITICAL	25	0	11	2026-04-21 08:41	View Download JSON
☐	Plugin Auditor	MEDIUM	1	0	0	2026-04-21 08:38	View Download JSON

Plugin Audit reports can be deleted or kept for reference

Vanilla Hair and Beauty

2

0

New

2

Howdy, wp-admin

Dashboard

Posts

Media

Pages

Comments

Google Reviews

Services

Manifest

Portfolio

Team

Appearance

Plugins1

Users

Tools

Available Tools

Import

Export

WordPress 6.9.4 is available! [Please update now.](#)

Plugin Audit Reports

Bedrock: Search engine indexing has been discouraged because the current environment is development.

☒	Plugin	Risk	High	Medium	Low	Date	Actions
☒	Satori ACF Field Loop	CLEAN	8	0	2	2026-04-21 09:04	View Download JSON
☒	Plugin Auditor	CLEAN	0	0	0	2026-04-21 09:03	View Download JSON
☒	Plugin Auditor	MEDIUM	1	0	0	2026-04-21 08:35	View Download JSON
☒	Media Library Folders Reset	CRITICAL	64	120	196	2026-04-20 19:18	View Download JSON
☒	Media Library Folders Reset	CRITICAL	64	120	196	2026-04-20 19:16	View Download JSON
☒	Media Library Folders Reset	CRITICAL	—	—	—	2026-04-20 17:52	View Download JSON

[Delete Selected](#) 6 selected

Plugin page highlighting the “Audit” CTA & access to Tools

The screenshot shows the WordPress admin interface. The top navigation bar includes a 'Howdy, wp-admin' greeting. The left sidebar contains a menu with items: Pages, Comments, Google Reviews, Services, Manifest, Portfolio, Team, Appearance, Plugins (with a red notification badge '1'), Installed Plugins (with an 'Add Plugin' link), Users, Tools, Settings, ACF, Yoast SEO (with a red notification badge '2'), WP2Social Auto Publish, and Media Library Organizer. The 'Plugins' menu item is highlighted, and a dropdown menu is open, listing: Available Tools, Import, Export, Site Health, Export Personal Data, Erase Personal Data, Plugin Auditor (highlighted with a blue bar), and Yoast Redirects. The main content area displays a list of installed plugins. The 'Plugin Auditor' plugin is highlighted in blue. A yellow notification banner states: 'There is a new version of Plugin Auditor available. [View version 2.4.3 details](#) or [update now](#).' The list of plugins includes: Media Library Folders, Media Library Folders Reset, Media Library Organizer, Plugin Auditor, Rich Showcase for Google Reviews, and ACF Field block for Query Loop. Each plugin entry shows its name, description, version, author, and links for activation, deactivation, audit, and details. The 'Plugin Auditor' entry has a 'Deactivate' and 'Audit' link. The 'Rich Showcase for Google Reviews' entry has a 'Connect Reviews' button and a 'Rate plugin' link with five stars.

Plugin Name	Description	Version	Author	Links
Media Library Folders	Gives you the ability to adds folders and move files in the WordPress Media Library.	Version 8.3.7	By Max Foundry	Activate Delete Audit View details
Media Library Folders Reset	Plugin for resetting Media Library Folders	Version 8.3.7	By Max Foundry	Activate Delete Audit View details
Media Library Organizer	Organize and Search your Media Library, quicker and easier.	Version 2.1.0	By Themeisle	Deactivate Audit Upgrade Rollback to v2.0.4 View details
Plugin Auditor	Audits WordPress plugins for security issues, coding standards violations, and permissions.	Version 1.0.1	By Plugin Auditor	Deactivate Audit View details
There is a new version of Plugin Auditor available. View version 2.4.3 details or update now .				
Rich Showcase for Google Reviews	Instantly display Google Map reviews on your website to increase user confidence and sales.	Version 6.9.4.4	By RichPlugins	Connect Reviews Deactivate Audit View details Rate plugin ★★★★★
ACF Field block for Query Loop	ACF Field block for Query Loop – output ACF fields inside Query Loop patterns.	Version 1.0.0	By Stephen Mason	Visit plugin site
Create and manage structured price lists	Create and manage structured price lists organised into sections. Output via a custom Gutenberg block. No external PHP dependencies.	Version 1.0.1	By Stephen Mason (Satori Digital)	Visit plugin site
Per-page popup block	Per-page popup block with customizable button/link, colors, and inner blocks.	Version 1.0.0	By Stephen Mason	Visit plugin site
An accessible, configurable Gutenberg block carousel	An accessible, configurable Gutenberg block carousel for any public post type.			



Plugin Audit report that has passed as clean and suitable for production

Beauty

2

0

New

2

Plugin Audit

×

Plugin Auditor

Audited: 2026-04-21 09:03

Risk: **CLEAN** (Score: 0)

No significant issues found. This plugin passed all security and code quality checks — no action required.

Severity	Count	Guidance
Critical	0	Fix immediately
High	0	Address urgently
Medium	0	Address when possible
Low	0	Review and consider
Info	6	Informational only

Dangerous Functions **PASS**

Output Escaping **PASS**

Download

Beauty

2

0

New

2

Plugin Audit

×

External HTTP Requests **PASS**

File Permissions **PASS**

Plugin Header / Metadata

Severity	File	Line	Message	Snippet
LOW	satori-acf-field-loop.php		Missing "Requires PHP" header.	
LOW	satori-acf-field-loop.php		Missing "Requires at least" header.	

Asset Versioning **PASS**

Error Suppression **PASS**

Obfuscated Calls **PASS**

Direct File Access Guard

Severity	File	Line	Message	Snippet
HIGH	satori-acf-field-loop.php		Missing direct file access guard add defined('ABSPATH') exit; at the top of the file.	
HIGH	includes/class-assets.php		Missing direct file access guard add defined('ABSPATH') exit; at the top of the file.	

Download



Plugin Audit report that Failed and clearly identifies issues

Plugin Audit

Satori Manifest

Audited: 2026-04-21 08:51

Risk: CRITICAL (Score: 125)

This plugin has 1 critical and 25 high severity issue(s) that require immediate action. With a risk score of 125, this plugin should not be used in production until the critical and high findings below have been resolved.

Severity	Count	Guidance
Critical	1	Fix immediately
High	25	Address urgently
Medium	0	Address when possible
Low	11	Review and consider
Info	6	Informational only

Plugin Audit

Input Sanitization

Severity	File	Line	Message	Snippet
HIGH	includes/class-meta-box.php	175	Unsanitized input: \$_POST accessed without sanitization.	? wp_unslash((string) \$_POST[self::POST_FIE LD])

Nonce Verification

Severity	File	Line	Message	Snippet
CRITICAL	includes/class-meta-box.php		File handles \$_POST data but has no wp_verify_nonce() or check_admin_referer() call.	

Capability Checks

Severity	File	Line	Message	Snippet
HIGH	includes/class-multisite.php	135	Write operation without a visible current_user_can() check in the preceding scope.	delete_option('satori_manifest_version');
HIGH	includes/class-multisite.php	136	Write operation without a visible current_user_can() check in the preceding scope.	delete_option('satori_manifest_patterns_se eded');
HIGH	includes/class-patterns.php	138	Write operation without a visible current_user_can() check in the preceding scope.	update_option('satori_manifest_patterns_se eded', SATORI_MANIFEST_VERSION, false);
HIGH	includes/class-plugin.php	113	Write operation without a visible current_user_can() check in the preceding scope.	update_option('satori_manifest_version', S ATORI_MANIFEST_VERSION);

Download



Plugin Audit report can be downloaded in json format

The screenshot shows a VS Code editor with the following components:

- EXPLORER:** A sidebar on the left showing the project structure. The 'WP-PLUGIN-AUDITOR' folder is expanded, showing files like `.claude`, `assets`, `includes`, `languages`, `templates` (containing `admin-reports.php`, `index.php`, `modal.php`, and `report.php` with 9+ errors), `tests`, `vendor`, `.eslintrc.json`, `.gitignore`, `.phpunit.result.cache`, `.wp-env.json`, `composer.json`, `composer.lock`, `index.php`, `LICENSE`, `package.json`, `phpcs.xml.dist`, `phpstan.neon.dist`, `phpunit.xml.dist`, `plugin-auditor.php`, `README.md`, `readme.txt`, and `uninstall.php` (with 8 errors).
- CLAUDE.md:** A file named `CLAUDE.md` is open in the editor.
- pla-Satori-ACF-Field-Loop-2026-04-21.json:** A JSON file is open in the editor, showing the audit report for the 'Satori ACF Field Loop' plugin. The report includes fields like `filename`, `plugin_name`, `plugin_file`, `risk` (CLEAN), `score` (0), `generated` (2026-04-21 09:04:01), `findings` (a list of findings), `database`, `credentials`, `errors`, `obfuscation`, `permissions`, `debug_output`, `redirects`, `role_checks`, `shortcodes`, `option_writes`, `wpdb_placeholders`, `requests`, and `meta` (a list of meta items).
- Terminal:** A terminal window at the bottom shows the command `wp-plugin-auditor` being executed.

```
{
  "filename": "pla-Satori-ACF-Field-Loop-2026-04-21.json",
  "plugin_name": "Satori ACF Field Loop",
  "plugin_file": "satori-acf-field-loop/satori-acf-field-loop.php",
  "risk": "CLEAN",
  "score": 0,
  "generated": "2026-04-21 09:04:01",
  "findings": {
    "dangerous": [],
    "output": [],
    "input": [],
    "nonces": [],
    "capabilities": [
      {
        "severity": "INFO",
        "file": "includes/class-rest.php",
        "line": 55,
        "snippet": "return current_user_can('edit_posts');",
        "message": "Capability check: current_user_can( 'edit_posts' )"
      }
    ]
  },
  "database": [],
  "credentials": [],
  "errors": [],
  "obfuscation": [],
  "permissions": [],
  "debug_output": [],
  "redirects": [],
  "role_checks": [],
  "shortcodes": [],
  "option_writes": [],
  "wpdb_placeholders": [],
  "requests": [],
  "meta": [
    {
      "severity": "LOW",
      "file": "includes/class-rest.php",
      "line": 55,
      "snippet": "return current_user_can('edit_posts');",
      "message": "Capability check: current_user_can( 'edit_posts' )"
    }
  ]
}
```